

Cybersecurity Analytics

01_overview.md — What the Domain is About & Industry Context

What is Cybersecurity Analytics? Cybersecurity Analytics is the application of data analysis, statistics, and machine learning to security data (logs, network traffic, endpoint events, threat intelligence) in order to detect, investigate, predict, and prevent cyber threats. It sits at the intersection of cybersecurity operations (SOC — Security Operations Center) and data science.

Why it matters (industry context):

- Organizations generate massive volumes of security telemetry daily (firewall logs, IDS/IPS alerts, endpoint detection logs, authentication logs, DNS logs). Manual review is impossible at scale — analytics is the only way to separate signal from noise.
- Rising threat sophistication (ransomware, APTs — Advanced Persistent Threats, insider threats, supply-chain attacks) means rule-based detection alone misses novel attacks; behavioral/statistical analytics fills that gap.
- Regulatory pressure (GDPR, HIPAA, PCI-DSS, SOC 2, India's DPDP Act) requires organizations to demonstrate monitoring, breach detection, and incident reporting capability.
- Cost of breaches is high — this creates strong business demand for analysts who can quantify risk, reduce Mean Time to Detect (MTTD) and Mean Time to Respond (MTTR), and justify security spend with data.
- Cybersecurity analytics roles exist across: SOC teams, Threat Intelligence teams, Fraud & Risk teams, GRC (Governance, Risk, Compliance), Product Security, and dedicated Security Data Science teams (increasingly at banks, fintechs, telecom, and SaaS companies).

Sub-areas within the domain:

- Network security analytics (traffic/flow analysis)
- Endpoint analytics (EDR data)
- Identity & access analytics (UEBA — User & Entity Behavior Analytics)
- Threat intelligence analytics
- Fraud analytics (often overlaps with cybersecurity in fintech/banking)

- Vulnerability management analytics
- Security compliance & audit analytics
- Incident response analytics / forensics

How this connects to a Data Analyst/Data Scientist role: Unlike a pure security engineer (who builds/configures tools), the analyst's job is to make sense of the data those tools produce — building dashboards, statistical baselines, anomaly detection models, and reports that drive decisions (block an IP, escalate an incident, patch a system, change a policy).

02_role_of_data_analyst.md — Day-to-Day Responsibilities

Core day-to-day tasks:

1. **Log/alert triage support** — Pull and aggregate logs from SIEM (Security Information & Event Management) tools; help SOC analysts prioritize alerts by adding statistical context (e.g., "this IP has hit 40 accounts in 10 minutes — 99th percentile").
2. **Dashboard building & maintenance** — Build/update dashboards (Power BI, Splunk, Kibana, Grafana) tracking KPIs like alert volume, MTTD, MTTR, false-positive rate.
3. **Threat data analysis** — Analyze patterns in phishing attempts, malware detections, failed logins, brute-force attempts; identify trends by geography, time, department, asset.
4. **Anomaly detection & modeling** — Build/maintain statistical or ML models to flag unusual login times, impossible travel (login from two distant locations in short time), unusual data exfiltration volumes, etc.
5. **Reporting to stakeholders** — Prepare weekly/monthly security posture reports for CISOs, risk committees, or leadership — translating technical findings into business risk language.
6. **Incident investigation support** — When an incident occurs, pull relevant historical data, build timelines, correlate events across systems (e.g., a phishing email → a login → a file download).
7. **Vulnerability & patch analytics** — Track vulnerability scan results, prioritize by exploitability + asset criticality (risk-based vulnerability management), monitor SLA compliance for patching.

8. **Compliance & audit support** — Pull evidence/data for audits (access logs, control effectiveness metrics) mapped to frameworks (ISO 27001, NIST, PCI-DSS).
9. **Threat intelligence enrichment** — Cross-reference internal alerts against external threat feeds (known malicious IPs, hashes, domains) to add context/confidence scores.
10. **Ad hoc investigations** — Answer specific questions from security/leadership teams, e.g., "How many employees clicked the phishing link in the last campaign?"

Skills exercised daily: SQL querying of log data, Excel/Power BI for reporting, Python for automation/modeling, understanding of networking basics (IP, ports, protocols), and communication skills to explain findings to non-technical stakeholders.

03_key_metrics_kpis.md — Domain-Specific KPIs & Metrics

Detection & Response Metrics:

- **MTTD (Mean Time to Detect)** — average time between a threat occurring and being detected.
- **MTTR (Mean Time to Respond/Resolve)** — average time from detection to remediation.
- **MTTC (Mean Time to Contain)** — time to isolate/contain a threat once identified.
- **Alert Volume** — total alerts generated per day/week (raw signal load on SOC).
- **False Positive Rate (FPR)** — % of alerts that are not actual threats; high FPR = analyst fatigue.
- **True Positive Rate / Detection Rate** — % of actual threats correctly flagged.
- **Alert-to-Incident Ratio** — how many raw alerts convert into confirmed incidents.

Vulnerability & Risk Metrics:

- **Vulnerability Density** — number of vulnerabilities per asset/system.
- **Patch Compliance Rate** — % of systems patched within SLA.
- **Risk Score / CVSS-weighted exposure** — aggregated risk based on vulnerability severity × asset criticality.
- **Time to Patch (TTP)** — average time to remediate a known vulnerability.

Identity & Access Metrics:

- **Failed Login Rate** — failed vs successful login attempts (brute-force indicator).
- **Privileged Account Activity** — monitoring of admin/root account usage.
- **Account Lockout Rate**
- **Anomalous Login Score** — model-driven score for unusual access patterns (location, device, time).

Phishing & Awareness Metrics:

- **Phishing Click Rate** — % of employees clicking simulated/real phishing emails.
- **Reporting Rate** — % of employees reporting suspicious emails.
- **Repeat Offender Rate** — employees repeatedly falling for phishing tests.

Data Loss & Exfiltration Metrics:

- **Data Exfiltration Volume** — abnormal outbound data transfer volume.
- **DLP (Data Loss Prevention) Incident Count**

Business/Compliance Metrics:

- **Cost per Incident**
- **Number of Audit Findings / Open Compliance Gaps**
- **SLA Adherence %** (for incident response, patching)
- **Security Posture Score** (composite index combining several KPIs, often used in exec dashboards)

04_common_datasets.md — Typical Data Sources/Fields Encountered

1. Network/Firewall Logs Fields: timestamp, source IP, destination IP, source port, destination port, protocol, action (allow/deny), bytes transferred, rule matched.

2. IDS/IPS Alerts (Intrusion Detection/Prevention Systems) Fields: alert ID, signature/rule name, severity, source/destination IP, timestamp, classification (e.g., malware, exploit attempt).

3. Authentication/Identity Logs (Active Directory, Okta, Azure AD) Fields: user ID, login timestamp, source IP/geo-location, device ID, login result (success/fail), MFA status, session duration.

4. Endpoint Detection & Response (EDR) Logs Fields: host ID, process name, parent process, file hash, registry changes, network connections initiated by process, detection verdict.

5. Email/Phishing Gateway Logs Fields: sender, recipient, subject, attachment hash, URL reputation score, spam/phishing classification, click/report status.

6. DNS Logs Fields: query timestamp, queried domain, requesting host, response IP, domain reputation/category.

7. Vulnerability Scan Data (Nessus, Qualys, Rapid7) Fields: asset ID, CVE ID, CVSS score, severity, discovery date, patch status, exploit availability.

8. Threat Intelligence Feeds Fields: IOC (Indicator of Compromise) type (IP/domain/hash), threat actor/campaign tag, confidence score, first/last seen date, source feed.

9. Cloud Security Logs (AWS CloudTrail, Azure Activity Logs, GCP Audit Logs) Fields: event name, actor identity, resource affected, region, timestamp, success/failure.

10. SIEM-Aggregated/Correlated Data Combines multiple sources above into normalized event schema (e.g., CEF/LEEF format), often the primary dataset an analyst queries directly.

11. Public/benchmark datasets for practice: CICIDS2017/2018, NSL-KDD, UNSW-NB15, CTU-13 (botnet), KDD Cup 99 (classic, dated), Kaggle phishing/malware datasets.

05_tools_technologies.md — Tools/Tech Stack Commonly Used

SIEM Platforms: Splunk, IBM QRadar, Microsoft Sentinel, Elastic (ELK) Stack, LogRhythm, ArcSight.

Querying/Analysis Languages: SQL, SPL (Splunk's Search Processing Language), KQL (Kusto Query Language — used in Microsoft Sentinel/Defender).

Programming/Scripting: Python (pandas, scikit-learn, numpy for modeling/automation), R (less common but used for statistical modeling).

Visualization/BI: Power BI, Tableau, Kibana, Grafana.

Threat Intelligence Platforms: MISP, Recorded Future, VirusTotal (for IOC lookups), AlienVault OTX.

Vulnerability Management: Nessus, Qualys, Rapid7 InsightVM, Tenable.io.

EDR/Endpoint Tools: CrowdStrike Falcon, Microsoft Defender for Endpoint, SentinelOne, Carbon Black.

Network Analysis: Wireshark, Zeek (Bro), NetFlow analyzers.

Cloud Security Monitoring: AWS GuardDuty, Azure Security Center/Defender for Cloud, GCP Security Command Center.

Data Engineering/Storage: Elasticsearch, Apache Kafka (log streaming), Hadoop/Spark (for very large-scale log analytics), SQL/NoSQL databases.

ML/Statistics libraries: scikit-learn (isolation forest, clustering), PyOD (outlier detection), statsmodels, TensorFlow/PyTorch (for deep learning-based detection at scale).

Frameworks referenced in analysis: MITRE ATT&CK (attack technique taxonomy), NIST Cybersecurity Framework, Cyber Kill Chain.

Collaboration/Ticketing: Jira, ServiceNow (for incident/case management), PagerDuty (alerting/escalation).

06_use_cases.md — Real-World Problems & Analytical Use Cases

1. **Brute-Force/Credential Stuffing Detection** — Analyze login attempt frequency/patterns per account and IP to flag automated attack attempts.
2. **Insider Threat Detection (UEBA)** — Build behavioral baselines per employee (typical login hours, data access volume, file downloads) and flag deviations (e.g., large download right before resignation).
3. **Phishing Campaign Analysis** — Measure click-through/report rates across departments, identify high-risk employee segments for targeted training.
4. **Anomalous Network Traffic Detection** — Identify beaconing behavior (regular, periodic outbound connections) indicative of malware command-and-control (C2) activity.
5. **Fraud/Account Takeover Detection** — Combine login geo-velocity ("impossible travel"), device fingerprint changes, and transaction patterns to flag account takeover in banking/fintech contexts.
6. **Risk-Based Vulnerability Prioritization** — Combine CVSS severity with asset criticality and exploit availability to rank which vulnerabilities to patch first (instead of patching by severity alone).
7. **Incident Timeline Reconstruction** — During a breach investigation, correlate logs across email, endpoint, and network systems to build a step-by-step attack timeline (often mapped to MITRE ATT&CK stages).

8. **DDoS/Traffic Spike Detection** — Statistical monitoring of traffic volume to detect denial-of-service patterns.
 9. **Data Exfiltration Detection** — Monitor outbound data transfer volumes per user/system against historical baselines.
 10. **Security Posture Reporting to Leadership** — Aggregate KPIs (patch compliance, phishing click rate, open incidents) into an executive dashboard for board-level risk conversations.
 11. **Third-Party/Vendor Risk Analytics** — Score vendor security posture using scan data and incident history.
 12. **Compliance Gap Analysis** — Identify controls not meeting framework requirements (e.g., ISO 27001 Annex A controls) using audit log data.
-

07_ml_techniques.md — ML/Statistical Models Relevant to the Domain

Anomaly Detection (most central technique in this domain):

- **Isolation Forest** — widely used for flagging rare/anomalous events in high-dimensional log data (e.g., unusual login behavior).
- **One-Class SVM** — learns "normal" behavior boundary, flags deviations.
- **Local Outlier Factor (LOF)** — density-based anomaly detection, useful for network traffic anomalies.
- **Autoencoders (deep learning)** — reconstruct "normal" traffic/log patterns; high reconstruction error = anomaly. Used at scale for network intrusion detection.
- **Statistical control charts / Z-score / EWMA** — simple baselining techniques for metrics like login counts, traffic volume.

Classification:

- **Random Forest / Gradient Boosting (XGBoost, LightGBM)** — classifying traffic/log entries as malicious vs benign, phishing vs legitimate email, given labeled historical data.
- **Logistic Regression** — simple, interpretable baseline classifier, often used for fraud/phishing scoring.
- **Naive Bayes** — historically strong for spam/phishing text classification.

Clustering & Behavioral Profiling:

- **K-Means / DBSCAN** — grouping similar user behavior profiles or network sessions for UEBA baselining.
- **Graph-based analysis** — modeling relationships between IPs, users, and devices as a graph to detect lateral movement or coordinated attacks (community detection, centrality measures).

Time-Series Analysis:

- **ARIMA / Prophet** — forecasting expected traffic/alert volume; deviations from forecast used as anomaly signal.
- **Sequence models (LSTM/RNN)** — modeling sequences of user actions or system calls to detect abnormal sequences (used in advanced EDR/UEBA systems).

NLP Techniques:

- Used for phishing email text/URL analysis, threat intelligence report parsing, and log message clustering (e.g., TF-IDF + clustering to group similar alert descriptions).

Rule-based / Hybrid Approaches:

- Signature-based detection (not ML but foundational — pattern matching known attack signatures) is often combined with ML for a layered detection strategy. Real-world systems rarely rely on ML alone; hybrid rule+ML systems reduce false positives.

Model evaluation considerations specific to this domain:

- Severe class imbalance (malicious events are rare) → prioritize Precision, Recall, F1, and PR-AUC over plain accuracy.
- False negatives (missed attacks) are typically far costlier than false positives — recall is often prioritized, but excessive false positives cause "alert fatigue," so a careful precision-recall tradeoff and cost-based thresholding is common practice.

08_resources.md — Reference Links, Datasets, Courses, Papers

Frameworks & Standards (read these first for domain vocabulary):

- MITRE ATT&CK: <https://attack.mitre.org/>
- NIST Cybersecurity Framework: <https://www.nist.gov/cyberframework>
- Cyber Kill Chain (Lockheed Martin) — search "Lockheed Martin Cyber Kill Chain"

Public Datasets for Practice:

- CICIDS2017/2018 (Canadian Institute for Cybersecurity):
<https://www.unb.ca/cic/datasets/ids.html>
- UNSW-NB15 dataset: search "UNSW-NB15 dataset"
- CTU-13 (botnet traffic dataset): search "CTU-13 dataset Stratosphere"
- Kaggle: search "phishing website dataset kaggle", "malware detection dataset kaggle"

Threat Intelligence References:

- VirusTotal: <https://www.virustotal.com/>
- MISP Project: <https://www.misp-project.org/>
- AlienVault OTX: <https://otx.alienvault.com/>

Courses/Certifications commonly pursued alongside this domain:

- CompTIA Security+ (foundational security knowledge)
- Splunk Core Certified Power User / Splunk fundamentals courses
- Microsoft SC-200 (Security Operations Analyst)
- Coursera/edX: "IBM Cybersecurity Analyst Professional Certificate"
- SANS courses (e.g., SEC401, SEC503 — more advanced/technical)

Books/Deeper Reading:

- "Applied Network Security Monitoring" by Chris Sanders & Jason Smith
- "Data-Driven Security" by Jay Jacobs & Bob Rudis
- "The Practice of Network Security Monitoring" by Richard Bejtlich

Project Lifecycle: What a Data Analyst/Scientist Actually Does, Step by Step

This section walks through a full cybersecurity analytics project end-to-end — e.g., "Build an anomaly detection system to flag suspicious login activity."

Step 1: Problem Framing & Stakeholder Alignment

- Meet with SOC lead/CISO to understand the actual pain point (e.g., "we're missing account takeover attempts" or "too many false alerts are burning out analysts").

- Define success criteria in business terms: reduce MTTD by X%, reduce false positive rate to under Y%, or flag Z% of known-bad historical incidents correctly.
- Clarify scope: which systems/logs are in-play (VPN logs? SaaS app logs? All of Active Directory?).
- Identify constraints: real-time detection needed vs batch/daily analysis; data privacy constraints (PII in logs).

Step 2: Data Discovery & Access

- Identify data sources (SIEM, Active Directory logs, VPN logs, EDR exports).
- Request access/credentials to relevant systems or data lake/warehouse where logs are stored.
- Understand data retention policies (security logs are often purged after 30-90 days unless archived).
- Document the schema of each log source and how sources can be joined (common keys: user ID, IP address, timestamp, host ID).

Step 3: Data Collection & Ingestion

- Pull historical log data via SIEM query language (SPL/KQL) or direct database/API access.
- Set up scheduled extraction if this will be an ongoing monitoring solution (e.g., daily batch pull via API or scheduled SQL job).
- Store working data securely (given sensitivity of security logs — access control matters even in the analysis phase).

Step 4: Data Cleaning & Preprocessing

- Handle inconsistent timestamp formats/timezones across log sources (critical in security — a 5-minute timezone mismatch can break correlation).
- Normalize IP addresses, resolve internal vs external, geolocate IPs (using IP-to-geo databases).
- Deduplicate repeated alerts (many SIEMs generate duplicate alerts for the same underlying event).
- Handle missing values (e.g., missing device ID for legacy systems).
- Parse unstructured fields (raw log text) into structured columns using regex or log-parsing libraries.

Step 5: Exploratory Data Analysis (EDA)

- Analyze login volume patterns by hour/day/user to understand "normal" baseline behavior.
- Visualize geographic distribution of logins, flag logins from unusual/high-risk countries.
- Check class balance if building a classifier (malicious vs benign events are typically very imbalanced, often <1% malicious).
- Correlate known historical incidents against the data to identify what signals preceded them.

Step 6: Feature Engineering

- Behavioral features per user: average login hour, typical login country/device, average session duration, days since last password change.
- Velocity features: number of failed logins in last 10 minutes, number of distinct IPs used in last hour, "impossible travel" flag (distance/time between two logins exceeds plausible travel speed).
- Aggregation features: rolling 7-day/30-day averages per user or per IP.
- Categorical encoding for device type, browser, protocol, geography.
- Graph features (if applicable): number of distinct users an IP has touched, centrality of a host in a lateral movement graph.

Step 7: Model Selection & Baseline Establishment

- Start with simple statistical baselining (Z-score/threshold-based rules) to establish a benchmark before jumping to ML.
- If sufficient labeled historical incident data exists, try supervised models (Random Forest, XGBoost) for classification.
- If labels are scarce (common in security), use unsupervised/semi-supervised anomaly detection (Isolation Forest, Autoencoder, LOF).
- Consider a hybrid: rule-based filters to remove obviously benign traffic, then ML on the remaining ambiguous cases.

Step 8: Model Training & Validation

- Split data carefully — time-based splits are preferred over random splits (train on past, validate on future, since attacker behavior evolves and future data must simulate a live deployment scenario).
- Address class imbalance using techniques like SMOTE, class weighting, or anomaly-detection framing instead of standard classification.
- Evaluate with Precision, Recall, F1, PR-AUC (not just accuracy, given imbalance) — and importantly, evaluate against a cost matrix (false negative cost >> false positive cost in most security contexts).
- Backtest against known historical incidents: does the model correctly flag past confirmed breaches?

Step 9: Threshold Tuning & Alert Design

- Choose a decision threshold that balances analyst workload (false positive rate) against detection coverage (recall) — often done in direct consultation with the SOC team who will act on the alerts.
- Design alert severity tiers (e.g., low/medium/high/critical) rather than a single binary flag, so SOC can prioritize triage.
- Add explainability to each alert (which features triggered it) so analysts trust and can act on the output — pure "black box" scores are hard to operationalize in SOC workflows.

Step 10: Deployment / Operationalization

- Integrate model output back into the SIEM or a dashboard so alerts appear where SOC analysts already work (Splunk, Sentinel, or a custom Power BI/Grafana dashboard).
- Set up automated scoring pipeline (batch daily or streaming real-time depending on requirement).
- Define escalation workflow: who gets notified, through what channel (SOAR playbook, ticket in ServiceNow, Slack/Teams alert).

Step 11: Monitoring, Feedback Loop & Model Maintenance

- Track model performance over time — false positive rate creep, analyst feedback ("this alert was not useful") fed back to retrain/adjust.
- Periodically retrain on new data since attacker behavior and normal business patterns shift ("concept drift" is a major issue in security ML).

- Maintain a feedback label pipeline: SOC analysts mark alerts as true/false positive, which becomes new training data.

Step 12: Reporting & Communication

- Build/maintain an executive-level dashboard summarizing detection performance, incident trends, and risk posture (translating technical detail into business risk language for leadership).
- Document methodology (for audit/compliance purposes — auditors often want to see how detection logic works).
- Present findings/recommendations in review meetings — e.g., "phishing click rate dropped 15% after Q2 training campaign" or "we now catch 80% of brute-force attempts within 5 minutes vs 45 minutes before."

Step 13: Continuous Improvement

- Incorporate new threat intelligence feeds as new IOCs emerge.
- Expand feature set/data sources as new log types become available (e.g., adding cloud infrastructure logs).
- Periodically reassess KPIs against evolving business risk priorities and threat landscape.